



Tarea #3

Tarea #3: Marcos Regulatorios y Análisis Avanzado de Seguridad

Profesor:

Dedaniel Urribarri

Elaborado por:

Luisdavid Colina V24766381

Fecha de solicitud: 12 de mayo del 2026

Fecha de Entrega: 18 de mayo 2026



Conceptos a Investigar

Problema de la Cadena de Confianza (Chain of Trust)

El problema de la cadena de confianza en la Infraestructura de Clave Pública (PKI) radica en la dependencia jerárquica para validar la autenticidad de un certificado digital [1]. Si una Autoridad de Certificación Raíz (Root CA) o una CA intermedia se ve comprometida debido a fallos de seguridad o la filtración de su clave privada, todos los certificados emitidos aguas abajo pierden su validez de inmediato. La mitigación de este riesgo técnico exige la implementación de mecanismos estrictos de revocación en tiempo real, tales como las Listas de Revocación de Certificados (CRL) y el Protocolo de Estado de Certificados en Línea (OCSP) [1].

Análisis Estático y Dinámico de Código (SAST y DAST)

El aseguramiento del software durante el ciclo de vida de desarrollo (SDLC) se divide en dos metodologías complementarias de inspección de vulnerabilidades:

- Static Application Security Testing (SAST): Es un enfoque de "caja blanca" que examina el código fuente, binarios o configuraciones sin ejecutar la aplicación [2]. Su objetivo es identificar fallos lógicos, inyecciones y malas prácticas de manera temprana.
- Dynamic Application Security Testing (DAST): Es un enfoque de "caja negra" que evalúa la aplicación en tiempo de ejecución desde el exterior [2]. Detecta vulnerabilidades operativas que solo se manifiestan en un entorno activo, tales como fallos de autenticación, gestión de sesiones y configuraciones incorrectas del servidor.

CISA (Cybersecurity and Infrastructure Security Agency)

CISA es la Agencia de Seguridad de Infraestructura y Ciberseguridad de los Estados Unidos, adscrita al Departamento de Seguridad Nacional [3]. Actúa como el asesor operativo nacional para la defensa cibernética y la protección de la infraestructura crítica. Su función principal es coordinar la respuesta ante incidentes, emitir directivas de mitigación obligatorias para agencias gubernamentales y publicar alertas técnicas sobre vulnerabilidades explotadas activamente en el ecosistema global.



NCA (National Cybersecurity Authority)

La NCA hace referencia conceptual a las Autoridades Nacionales de Ciberseguridad establecidas por diversos Estados para gobernar su estrategia de defensa digital. En el contexto de marcos regulatorios modernos (como la Directiva NIS2 en la Unión Europea), la NCA es el organismo gubernamental designado por cada país miembro con la responsabilidad de supervisar el cumplimiento de las normativas de seguridad, gestionar la notificación de incidentes cibernéticos significativos y aplicar sanciones a las entidades esenciales que no adopten las medidas de resiliencia exigidas [4].

ISO/IEC 27001

ISO/IEC 27001 es el estándar internacional que especifica los requisitos para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de la Seguridad de la Información (SGSI) [5]. Basado en un enfoque de gestión de riesgos, el estándar proporciona un marco estructurado para proteger la confidencialidad, integridad y disponibilidad de los activos de información mediante controles organizacionales, humanos, físicos y tecnológicos detallados en su Anexo A.



Conclusiones

El estudio de estos conceptos permite evidenciar la complementariedad entre los controles técnicos internos y los marcos regulatorios internacionales en la gestión de la seguridad. Se concluye que:

- La robustez de los mecanismos de autenticación depende directamente de la integridad de la Cadena de Confianza, la cual debe ser verificada constantemente para evitar brechas estructurales.
- La combinación de las metodologías SAST y DAST garantiza que las aplicaciones sean resilientes tanto en su diseño lógico inicial como durante su interacción en entornos de producción.
- La gobernanza global y el cumplimiento normativo encuentran su base en agencias operativas como CISA, directrices regulatorias supervisadas por las NCA y la estandarización de procesos mediante la norma ISO/IEC 27001, configurando un ecosistema donde la seguridad técnica se alinea con la conformidad legal y la continuidad del negocio.



Referencias

- [1] National Institute of Standards and Technology (NIST), "Public Key Infrastructure (PKI) Trust Models," NIST SP 800-32, 2021.
- [2] OWASP Foundation, "A Guide to Application Security Testing Technologies," OWASP Core Projects, 2023.
- [3] Cybersecurity and Infrastructure Security Agency (CISA), "About CISA: Mission and Mandate," U.S. Department of Homeland Security, 2025.
- [4] European Union Agency for Cybersecurity (ENISA), "National Cybersecurity Authorities: Role and Responsibilities under the NIS Directive," ENISA Publications, 2024.
- [5] International Organization for Standardization (ISO), "ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements," ISO, 2022.